TP 1 WiFi	INSA-Lyon
Sécurité des Protocoles Réseaux	Département Télécom
Aircrack, WEP, WPA et WPA2	Walid Bechkit

Objectifs : Dans la continuité du cours sur la sécurité WiFi, l'objectif de cette première séance de travaux pratiques est de mieux comprendre le protocole WEP et de savoir mener une attaque complète contre ce protocole. Les attaques que nous mettrons en place permettront de retrouver une clé WEP tout en comprenant le fondement théorique des différentes étapes. Un autre objectif est de comprendre les protocoles WPA et WPA2 et quelques attaques potentielles contre ces protocoles. Les sous-objectifs de cette séance se déclinent comme suit :

- Prendre en main Aircrack et ses outils : airmon-ng, airodump-ng, aireplay-ng, et aircrak-ng
- Mesurer la facilité d'écoute de canal en WiFi et mettre en place une capture des paquets
- Mieux comprendre l'authentification WEP-PSK et savoir mener une fausse authentification dans les différents scénarios (existence ou non d'autres clients)
- Savoir mener des attaques d'injection de paquets (requêtes ARP) et comprendre leur intérêt.
- Savoir retrouver les clés WEP et comprendre le fondement théorique derrière
- Comprendre l'authentification WPA/WPA2 à travers l'analyse de traces.
- Capturer et analyser les paquets de distribution de clés (4-Way Handshake)
- Mener une attaque par dictionnaire contre WPA/WPA2
- Mettre en place un point d'accès illicite et comprendre les risques liés.

Mots clés : *WEP, authentification, confidentialité, Aircrack, clé WEP, vecteur d'initialisation, RC-4, CRC, WPA, authentification, confidentialité, Aircrack, 4-Way Handshake , Attaque par dictionnaire.*

Remerciements : Une partie de ce TP a été inspirée par les différents tutoriaux disponibles sur https ://www.aircrack-ng.org/doku.php ?id=tutorial et par des TPs préparés et assurés par Matthieu Cunche (INSA-Lyon) et Francois Lusieur (INSA-Lyon) que je tiens à remercier.

1 Préambule

Durant ce TP, nous utiliserons des cartes Yun qui sont des cartes Arduino combinant à la fois Arduino et Linux. Ces cartes sont fabriquées avec Dog Hunter, une entreprise spécialisée dans le développement de cartes embarquées sous Linux

Les cartes Yun intègrent un micro-contrôleur ATMega32U4 cadencé à 16 MHz et un chip Atheros AR9330 (IEEE 802.11n 1x1 2.4 GHz Systemon-a-Chip (SoC)) adapté aux réseaux locaux sans fil, aux points d'accès et aux routeurs et fonctionnant sous une distribution Linux basée sur OpenWRT.

2 Configuration

2.1 Connection aux cartes Arduino Yun

Commencez par vous connecter aux cartes Arduino Yun en mettant en place une liaison filaire. Les interfaces Ethernet des Yun utilisées dans ce TP sont configurées avec des adresses IP statiques 192.168.44.2/24. Configurez donc l'interface Ethernet de votre PC avec une adresse du réseau 192.168.44.0/24 et connectez vous à travers Putty aux Yun. Connectez vous en root (mot de passe : arduino)

2.2 Paramètres des cartes réseaux

En utilisant la commande ifconfig, affichez les paramètres (Adresse MAC et Adresse IP) de vos interfaces filaires et sans fil

```
#ifconfig
```

Notez ces paramètres :

En utilisant la commande iwconfig, visualisez les interfaces sans fil de votre carte.

```
#iwconfig
```

La commande iwconfig est similaire à ifconfig mais elle est dédiée aux interfaces sans fil. Elle peut être utilisée pour définir les paramètres de l'interface réseau spécifiques aux opérations sans fil.

3 Scan du réseau et capture des paquets

3.1 Démarrage de l'interface WiFi en mode monitor

En utilisant la commande airmon-ng, démarrez l'interface wlan0 en mode monitor. Ce mode permet de capter tous les paquets qui transitent y compris ceux qui ne vous sont pas adressés.

```
#airmon-ng start wlan0
```

Vous pouvez préciser le numéro de canal choisi à la fin de cette commande.

En utilisant la commande iwconfig, vérifiez la création d'une interface de monitoring (appelée par défaut mon0). Cette interface sera celle qu'on utilisera pour la suite de ce TP.

```
#iwconfig
```

A partir de là, nous utiliserons uniquement l'interface de monitoring mon0. Éteignez l'interface wlan0 :

```
#ifconfig wlan0 down
```

3.2 Scan du réseau et capture des paquets

En utilisant la commande airodump-ng, démarrez le scan de tous les réseaux sans fil.

```
#airodump-ng mon0
```

Donnez l'explication de toutes les colonnes que vous observez :

En utilisant l'option help donnez les commandes qui permettent de filtrer les réseaux par type de chiffrement ? par bssid ?

Avant de stocker vos nouveaux paquets, il est conseillé de supprimer les anciennes traces sur vos cartes SD.

Attention : Ne supprimez que les fichiers avec extensions csv cap netxml et xor. La carte SD contient des dossiers que nous utiliserons plus tard.

```
#cd /mnt/sda1
#rm *.csv *.cap *.netxml *.xor
```

L'option -w permet de sauvegarder les paquets capturés dans un fichier choisi. Tapez la commande suivante afin de sauvegarder vos paquets.

```
#airodump-ng -c num - -bssid xx :xx :xx :xx :xx :xx -w /mnt/sda1/MesCapturesWEP mon0
```

Tel que :
num est le numéro du cannal du réseau nommé ReseauWEP xx :xx :xx :xx :xx :xx est le BSSID du réseau nommé ReseauWEP (MAC du AP).

IMPORTANT : A partir de cette étape, lancez un nouveau terminal et observez de temps en temps l'évolution de la capture de paquets dans le premier terminal.

4 Rejeu des requetes ARP d'autres clients

La capture d'un nombre important de paquets suffira pour casser la clé WEP comme expliqué dans la dernière section de ce TP. Afin d'accélérer le calcul de la clé WEP, nous allons effectuer un rejeu de paquets et une injection de nouveaux paquets. Dans le cas où un ou plusieurs clients sont présents dans le réseau, il vous suffit de capturer une ou plusieurs requêtes arp et de les rejouer, ce qui permettra la génération de nouveaux vecteurs d'initialisation IVs. Pour cela tapez la commande :

```
aireplay-ng -3 -b xx :xx :xx :xx :xx :xx -h zz :zz :zz :zz :zz :zz mon0
```

Tel que :

xx :xx :xx :xx :xx :xx est le BSSID du réseau nommé ReseauWEP (MAC du AP).
zz :zz :zz :zz :zz :zz est l'adresse MAC d'un client déjà associé.

Vous devez remarquer l'augmentation du nombre de paquets de données dans le premier terminal. Quelle est le nombre moyen de données par seconde ?

Utilisez maintenant l'option -x et faites varier la valeur de cette option de 10 à 800 par exemple. Notez à nouveau le nombre moyen de données par seconde dans le premier terminal ? A quoi sert cette option ?

N'oubliez pas que vous êtes nombreux, vous pouvez donc fixer cette valeur à 20 par exemple.

5 Injection de nouvelles requetes ARP

IMPORTANT : Si vous arrivez à rejouer un nombre important de requêtes ARP et ainsi obtenir un nombre important d'IV, les attaques statistiques (section 6) peuvent être mener sans besoin d'injecter de nouveaux paquets. Si vous manquez de temps durant le TP, vous pouvez donc passer directement à la section 6, sinon n'hésitez pas à injecter de nouveaux paquets comme expliqué dans cette section.

Dans cette section, vous allez apprendre comment injecter vos propres requêtes ARP afin d'accélérer la capture de paquets. Afin de pouvoir lancer une injection de paquets, la station malveillante doit être associée et authentifiée. Dans ce qui suit, nous commencerons par expliquer comment mener une fausse authentification et nous passerons ensuite à l'injection des requêtes ARP.

5.1 Mener une fausse authentification

Comme vu en cours, deux systèmes d'authentification sont possibles : WEP Open System et WEP Pre-Shared Key.

5.1.1 Authentification WEP Open System

Si le système d'authentification ouvert est utilisé, il est très simple de s'authentifier en utilisant la commande

```
#aireplay-ng -1 0 -e ReseauWEP -h yy :yy :yy :yy :yy :yy mon0
```

Tel que :
yy :yy :yy :yy :yy :yy est votre adresse MAC.

Si le système d'authentification ouvert est utilisé, une fois authentifié, vous pouvez passer à la sous-section suivante (Section 5.2) afin d'injecter des requêtes ARP.

5.1.2 Analyse théorique de traces d'authentification à clé partagée

Cependant, la majorité des systèmes utilisant WEP se basent sur l'authentification à clé partagée. Comme vu en cours, cette dernière se base sur le principe de challenge/response.

Afin de mieux comprendre l'authentification à clé partagée, analysez en reprenant votre cours, le fichier "wep.shared.key.authentication.cap"

En analysant le premier beacon, donnez le nom du SSID, le BSSID, les débit supportés, et le cannal utilisé pour ce scénario.

En analysant les paquets suivants (ignorez les acquittement 802.11), retrouvez les échanges permettant l'authentification et l'association de la station auprès du réseau sans fil.

5.1.3 Retrouvez la suite chiffrante dans le cas d'une authentification à clé partagée

Afin de mener une fausse authentification à clé partagée, il faudrait d'abord retrouver la suite chiffrante. Plusieurs possibilités sont offertes afin de retrouver cette suite :

- Capturer une vraie demande d'authentification et déduire une partie de la suite chiffrante en appliquant un xor entre le challenge et la réponse (R1 XOR C1 = (keystream(key ‖ IV1) XOR C1) XOR C1)
- Causer volontairement une dés-association des clients attachés (ou d'un client) et capturer la nouvelle demande d'authentification afin de déduire une partie de la suite chiffrante.

  aireplay-ng -0 1 -a xx :xx :xx :xx :xx :xx mon0 (-c pour préciser un client en particulier)

- Utiliser l'attaque Chopchop (attaque vue en cours sous le nom de KoreK attack) qui permet de déduire la suite chiffrante octet par octet grâce au CRC.

Afin de tester cette troisième méthode, lancez la commande :

aireplay-ng -4 -a xx :xx :xx :xx :xx :xx -h zz :zz :zz :zz :zz :zz mon0

Tel que :
xx :xx :xx :xx :xx :xx est le BSSID du réseau nommé ReseauWEP (MAC du AP).
zz :zz :zz :zz :zz :zz est l'adresse MAC d'une station déjà authentifiée..

Vous pouvez utiliser l'option -m pour préciser la taille minimale des paquets à utiliser. Pour réussir la fausse authentification, vous devez choisir un paquet dont la taille T est importante (1400). Afin de faire vite, choisissez plutôt un paquet de faible taille et le résultat d'un paquet long sera fourni par la suite.

Si l'attaque réussit, la console affiche "Completed" et deux fichiers sont générés (un fichier .cap et un ficher .xor). Bravo ! c'est ce dernier .xor qui contient les T premiers octets de la suite chiffrante.

Quel est le nombre moyen d'octets découverts par seconde ?

5.1.4 Lancer la fausse authentification à clé partagée

Maintenant que vous avez le début de la suite chiffrante, vous pouvez facilement lancer une fausse authentification auprès du point d'accès. Pour cela lancez la commande :

```
aireplay-ng -1 0 -e ReseauWEP -y monfichier.xor -a xx :xx :xx :xx :xx :xx -h yy :yy :yy :yy :yy :yy mon0
```

Tel que :
monfichier.xor est votre fichier .xor ou le fichier replay_WEP fourni
yy :yy :yy :yy :yy :yy est votre adresse MAC
xx :xx :xx :xx :xx :xx est le BSSID (adresse MAC du point d'accès)

Quel est le message affiché ?

5.2 Injection des requêtes arp

Notez le nombre moyen de paquets de données par seconde dans le premier terminal où la capture des paquets et des beacon est en cours.

Une fois votre client authentifié, vous pouvez injecter des requêtes arp grâce à la commande :

```
aireplay-ng -3 -b xx :xx :xx :xx :xx :xx -h yy :yy :yy :yy :yy :yy mon0
```

Cette commande permet d'écouter les requêtes arp et de les injecter en fixant votre adresse MAC comme adresse source. Le point d'accès rediffusera ces requêtes avec des nouveaux IV à chaque fois, ce qui maximise le nombre d'IV circulant sur le réseau. Vous devez remarquer l'augmentation du nombre de paquets de données dans le premier terminal. Quelle est le nombre moyen de données par seconde ?

6 Trouver la clé WEP

Quand vous arrêtez la capture de paquets dans le premier terminal, un fichier .cap contenant toutes les traces sera crée. Sur la base de ce fichier (ou des fichiers si vous en avez plusieurs), on peut retrouver la clé WEP grâce aux méthodes vues en cours. Néanmoins, faites attention ; il vous faut souvent au moins quelques dizaine de milliers d'IV différents pour pouvoir retrouver la clé.

Afin de retrouvez la clé lancez la commande :

```
aircrack-ng -b xx :xx :xx :xx :xx :xx /mnt/sda1/*.cap
```

Cela prendra en compte toutes les traces de tous les fichiers .cap du répertoire choisi. Vous pouvez évidement préciser un seul fichier. Quel est le nombre d'IV différent trouvé par aircrack-ng ? Quel est le résultat de la commande ?

Bravo ! vous avez pu retrouver une clé WEP sur 128 bits (104+24). Donnez cette clé.

Les fichiers capture_WEP_more1.cap et capture_WEP_more2.cap contiennent des traces venant de deux autres réseaux (un avec une clé WEP-64 et l'autre avec une clé WEP 128 bits)

Lancez la commande :

```
aircrack-ng capture_WEP_more1.cap
```

Combien de point d'accès sont concernés par cette capture ? Choisissez celui qui utilise WEP et lancez la commande avec l'option -h. Quel est le nombre d'IVs différents trouvé par aircrack-ng ? Quel est le résultat de la commande ? Bravo ! vous avez pu retrouver une clé WEP sur 64 bits. Donnez là.

Lancez la commande :

```
aircrack-ng capture_WEP_more2.cap
```

Quel est le nombre d'IV différent trouvé par aircrack-ng ? Quel est le résultat de la commande ? Bravo ! vous avez pu retrouver une clé WEP sur 128 bits. Donnez là.

7 Analyse théorique de traces WPA

L'objectif de cette section est d'illustrer les différentes phases opérationnelles du WPA/WPA-2 à travers l'analyse détaillée des traces disponibles sur le site officiel d'AirCrack.

7.1 Authentification réussie

Ouvrez le fichier wpa_full.cap fourni et analysez les différents paquets en répondant aux questions suivantes :
Quel est le rôle du paquet 1 (beacon frame) ? Quelles sont les principales informations qu'on peut retrouver dans le champ IEEE 802.11 wireless LAN management frame –> Tagged parameters ?

Quel est le rôle des paquets 2 et 3 (probe request and probe response) ? Quelles sont les principales informations qu'on peut retrouver dans IEEE 802.11 wireless LAN management frame –> Tagged parameters ?

Le chiffrement unicast et multicast seront ils assurées en utilisant TKIP ou CCMP ?

Les paquets 4 et 5 sont la requête et la réponse de l' "open authentication system". La réponse est toujours positive.

Quel est le rôle des paquets 6 et 7 ? Quelles sont les principales informations qu'on peut retrouver dans IEEE 802.11 wireless LAN management frame –> Tagged parameters ?

Trouvez le champ qui mentionne le type d'authentifcation : WPA-PSK(personnel) ou WPA-EAP (entreprise)

Les paquets que vous avez analysé jusque là correspondent à la phase 1 (Mise en accord sur la politique de sécu) des phases opérationnelles du 802.11i (voir cours). Dans ce scénario, on se base sur une clé partagée : WPA-PSK (WPA-Personnel), c'est pourquoi la phase 2 (authentification 802.1x) n'est pas mise en place. Nous allons directement observer des échanges de la phase 3 (dérivation et distribution des clés).

A quoi correspondent les paquets 8 à 11 ?

Donnez les 5 premiers octets des deux valeurs aléatoires proposées par le client et le point d'accès ?

A quoi correspondent les paquets 12 à 15 ?

Identifiez les Vecteurs d'initialisation ICV ? comment sont ils gérés ?

7.2 Authentification non réussie

Nous allons maintenant analyser le cas d'une authentification non réussie. Ouvrez le fichier wpa_bad_password.cap Y a-t-il une différence dans les premiers paquets (1 à 7) ? pourquoi ?

Analysez les paquets 8 et 9 ? Comment le point d'accès déduit que le client ne possède pas le bon secret ?

Combien de tentatives sont offertes au client ?

8 Capture de l'authentification WPA (paquets du handshake WPA)

Revenons maintenant à la partie pratique en essaynt de mener des attaques contre WPA/WPA2 en utilisant Aircrack. Afin de capturer les paquets handshake WPA, il faut lancer la capture des paquets et attendre dans l'espoir qu'un client se connecte au réseau. Sinon, déclenchez la dés-authentification d'un client déjà authentifié afin de provoquer une nouvelle demande d'authentification.

Afin de déclencher la dés-authentification déjà associée, lancez la commande :

```
aireplay-ng -0 1 -a xx :xx :xx :xx :xx :xx -c zz :zz :zz :zz :zz :zz mon0
```

Tel que :
xx :xx :xx :xx :xx :xx est le BSSID du réseau nommé ReseauWPA (MAC du AP).
zz :zz :zz :zz :zz :zz est l'adresse MAC d'un client déjà associé.

Quel est le message affiché ?

N'hésitez pas à lancer cette commande plusieurs fois si vous n'observez pas de paquets du handshakeWPA.

9 Attaque par dictionnaire WPA

Une des attaques les plus utilisées contre WPA est l'attaque par dictionnaire. Pourquoi à votre avis ?

Afin de lancer une attaque par dictionnaire, l'idée est de tester tous les secrets inclus dans un dictionnaire donné. En revoyant les détails des deux premiers paquets du WPA handshake, expliquez la démarche à suivre dans une attaque par dictionnaire contre le protocole WPA.

Lancez une attaque par dictionnaire en utilisant aircrack-ng.

```
aircrack-ng -w rockyou.txt -b xx :xx :xx :xx :xx :xx fichier.cap
```

Tel que :
xx :xx :xx :xx :xx :xx est le BSSID du réseau nommé ReseauWPA (MAC du AP).
rockyou.txt est un dictionnaire (parmi les dictionnaires les plus utilisés)
fichier.cap est votre fichier contenant le WPA handshake.

Ps :

- Vous pouvez lancer aircrack-ng sans préciser le BSSID du réseau à attaquer. aircrack-ng vous proposera la liste de tous les réseaux.
- Idéalement, lancez aircrack-ng en utilisant votre fichier .cap mais si vous n'arrivez pas à capturer le handshake, lancez aircrack-ng sur le fichier fourni capture_WPA_handshake.cap qui a été capturé en utilisant le même réseau (même SSID, BSSID et clé WPA).

Bravo ! vous avez pu retrouver la clé WPA, notez cette clé.

Quel est le nombre moyen de clés testées par seconde ?

Les cartes Yun ont des capacités de calcul limitées. Si on suppose qu'un ordinateur est 1000 fois plus rapide et sachant que les dictionnaires français (resp. anglais) complets comptent environ 100 000 (resp. 200 000) mots. Quel est le temps nécessaire pour parcourir tous les mots du français ? d'anglais ? du dictionnaire rockyou ?

D'autres dictionnaires des mots de passe les plus utilisés sont disponibles sur internet. Vous pouvez télécharger quelques uns et les tester.

10 Point d'accès illicite (Rogue Access Point)

Une des attaques les plus dangereuses est l'attaque de point d'accès illicite. Cette attaque peut prendre plusieurs formes parmi lesquelles nous testerons deux :

10.1 Karma attack

Dans cette attaque, le point d'accès répond à toutes les demandes "probe request" indépendemment du SSID spécifié dans la requête. Afin de mettre en place ce mode, utilisez la commande :

```
airbase-ng -c 11 -P -C 60 -v mon0
```

Quels sont les messages que vous observez ?

10.2 AP spoof attack

Une autre attaque est de mettre en place un point d'accès illicite tout en précisant un ou plusieurs SSID. Afin de lancer cette attaque utilisez :

```
airbase-ng -c 11 -e "reseau_public" -v mon0
```

Quels seraient les meilleures SSID à choisir à votre avis ?

Utilisez l'option -E au lieu de -e afin d'annoncer plusieurs réseaux

Afin de maximiser la quantité d'informations capturées grâce à cette attaque, l'idéal est de pouvoir fournir aux différents clients un accès internet. Expliquez les différentes étapes afin d'offrir un accès internet aux clients associés.

Une fois le point d'accès illicite mis en place, vous pouvez capturer tout le trafic. Quelles sont les informations sensibles que vous pouvez capturer ? Afin de mesurer la sensibilité de cette attaque, analysez les traces FTP fournies.